

mitigate this risk, an entity should include legal counsel to help guide the engagement and help avoid potential contractual issues. For additional information on contracting,²²¹ refer to the [“Contracts and Other Agreements”](#) section of this booklet.

For more information on third-party risk management, refer to the *FFIEC IT Handbook’s* [“Outsourcing Technology Services”](#) booklet.

VI.D Evaluation

A formal process for evaluating RFI, RFP, and RFQ responses produces higher quality selections of third parties across the entity and reduces legal risk. The process goal should be a fair and consistent approach to evaluating and eventually selecting a third-party provider. The process should include procedures to compare each proposal or quote to the entity’s defined requirements for the systems, components, or services needed. Then, the entity can compare all the proposals or quotes that meet those requirements. When the process includes pre-determined evaluation criteria, the process is more equitable and legal risk is reduced. Careful consideration helps management determine appropriate evaluation criteria that assists in the review of the widely varying proposals (e.g., bidders proposing either SaaS, infrastructure-as-a-service [IaaS], or platform-as-a-service [PaaS])²²² to meet the basic requirements. Table 3 lists evaluation criteria examples.

Table 3: Evaluation Criteria Examples for Third-Party Solicitations

General criteria for all products and services:

- | | |
|--|--|
| <ul style="list-style-type: none"> • Ability to audit or receive independent audit reports. • Confidentiality and privacy standards. • Copyright standards. • Delivery dates. • Liability limitations. • Licensing restrictions. • Maintenance procedures. • Financial performance and condition. • Information security requirements set by the entity. • Backup and resilience options. • Costs, fees, and discounts. | <ul style="list-style-type: none"> • Operations and internal controls. • End-of-service or EOL. • Legal and regulatory requirements. • Subcontractor details. • Testing standards. • Third-party service provider customer reference. • Training provided. • Warranty specifications. • Event or incident response roles and responsibilities. • Insurance considerations. |
|--|--|

Software products and services:

- | | |
|---|---|
| <ul style="list-style-type: none"> • Compatibility of Oss. • Escrow criteria. | <ul style="list-style-type: none"> • Next release date. • Programming language. |
|---|---|

²²¹ Refer to the following guidance: [Interagency Guidance on Third-Party Relationships: Risk Management](#), as noted in OCC Bulletin 2023-17, [“Third-Party Relationships: Interagency Guide on Risk Management”](#); FDIC FIL-29-2023, [“Interagency Guidance on Third-Party Relationships: Risk Management”](#); and FRB SR Letter 23-4, [“Interagency Guidance on Third-Party Relationships: Risk Management.”](#) Also see CFPB Compliance Bulletin and Policy Guidance; 2016-02, [“Service Providers.”](#)

²²² Refer to the *FFIEC IT Handbook’s* [“Architecture, Infrastructure, and Operations”](#) booklet for more information on SaaS, IaaS, and PaaS.

Hardware products and services:

- | | |
|---|---|
| <ul style="list-style-type: none"> • Maintenance requirements (for the entity and the third party). • Capacity (e.g., memory, bandwidth, storage, power). | <ul style="list-style-type: none"> • Servicing options. • Performance capabilities. |
|---|---|

For more information on evaluation considerations, refer to the *FFIEC IT Handbook*'s "[Outsourcing Technology Services](#)," "[Architecture, Infrastructure, and Operations](#)," "[Information Security](#)," and "[Management](#)" booklets.

VI.E Contracts and Other Agreements

Contracts and other types of agreements are used to document the terms and conditions under which systems, components, and services are provided. Acquisition policies, standards, and procedures specify how contracts and other agreements are documented, reviewed, and approved. Agreements²²³ take many forms and may be included in a contract by reference. Agreement examples are statements of work (SOW), master services agreements (MSA), SLAs, and escrow agreements. To ensure that contracts and other agreements are legally enforceable, legal counsel should be involved in the acquisition process before finalization. Contracts are intended to be legally binding agreements between two or more parties. They generally identify the goods and services to be provided, the time frame for provision, and the associated costs and fees. There may be several documents involved in the procurement process; therefore, it is helpful to identify each of the agreements and contracts, which will assist management in completing the evaluation and selection steps. These documents may be useful to management in its effective oversight of the performance of the entity's supply chain partners. The following subsections describe several agreements and contracts commonly encountered during examinations.

VI.E.1 Statement of Work

An SOW is one supporting document for contracts, detailing the activities to be performed and the activity output in system and component development (e.g., performance level, operating reports, developer documentation, and user manuals). This documentation is critical to system and component maintenance because it details maintenance standards for operations. SOWs can also specify the security assurance requirements (e.g., code reviews, penetration tests, and SOC reports). The security assurance requirements should include the processes that the developer and other staff will follow. Additionally, the SOW may specify the verification process for delivery of products and services, including what task completion evidence is required for payment. SOWs often become part of a binding agreement, such as a contract.

While the contract defines the legal aspects of the relationship, the SOW generally contains elements, such as the following:

- Purpose of the relationship.

²²³ For purposes of this booklet, *Black's Law Dictionary* defines "[agreement](#)" as "the consent of two or more persons concurring, the one in parting with, the other in receiving, some property, right, or benefit."

- Project objectives.
- Services and products to be provided (i.e., scope of work).
- Schedule, including deliverables and delivery deadlines.
- Requirements for providing the desired services and products, including potential penalties or payment retention for unsatisfactory work.
- Objective measure of satisfactory completion of work.
- Payment due date and method.
- Legal and regulatory requirements.
- Location and duration of the work.
- Acceptance criteria.

There is no standard SOW format across entities and industries. It is up to appropriate stakeholders at the examined entity to determine the format according to the entity's needs. Effective entities provide guidance to relevant personnel in support of a structured approach to SOW development to promote consistent and positive acquisition results, often achieved through SOW training. Similarly, involving all stakeholders in SOW development and establishing an appropriate management review and approval process are both effective practices in achieving positive acquisition results consistently across an entity.

SOW details are important because the type, duration, and complexity of work varies significantly. Clear and specific SOWs help increase the likelihood that bids are comparable, that selection decisions are made quickly, and that miscommunication and misunderstanding are avoided. For example, the SOW should identify the responsibilities of all parties involved. One risk is that service and outsourcing providers can become so focused on the customer entity's needs and requirements that they overlook their own. In order to meet requirements and provide for delivery of a quality product or service, it is important that the provider's needs and requirements (e.g., price, security, and interoperability) also be specified and met. Another example of effective SOW details includes the documentation required from supply chain partners.²²⁴ When an SOW is specific, it can be used to measure whether requirements have been met to an acceptable level.

An SOW may include elements, such as the following:

- Statement of confidentiality.
- Description of work with assumptions and constraints.
- Services to be provided.
- Facility and security requirements.
- Marketing requirements.
- Transition requirements.
- Training and reporting requirements.
- Roles and responsibilities.
- Schedule.

²²⁴ Refer to NIST SP 800-161r1, [Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations](#), and NIST's Response to Executive Order 14028, [Software Supply Chain Guidance: Software Security in Supply Chains](#).

- Pricing.
- Approvals.
- Glossary.
- Appendix (e.g., containing an incident response plan with contractor responsibilities).

In addition to SOWs, there are alternative methods²²⁵ to document details for proposals (e.g., RFI, RFP, and RFQ), which support the contract or other agreements. One example of these alternatives includes a statement of objectives (SOO), which identifies the broad business outcomes and objectives for performance.²²⁶ An entity makes a request for detailed proposals (i.e., an SOO), which are provided in response. Another alternative is a performance work statement (PWS),²²⁷ which emphasizes outcomes, desired results, and objectives at a more detailed and measurable level. An appropriate response is furnished by prospective providers. These alternative methods may be used in conjunction with the other documents noted above (e.g., RFI, RFP, and RFQ). Information from the SOO or PWS may then be included into the contract to produce a more effective engagement.

VI.E.2 Master Services Agreement

MSAs are “master” documents that govern multiple agreements or transactions between entities. The MSA often sets forth the principal legal terms that govern the parties’ relationship and are usually drafted by the service provider. An MSA usually governs or incorporates additional contract documents, such as software license agreements, policies and procedures, terms and conditions, data protection agreements, end-user license agreements, and SOWs. These additional contract documents provide important information to operations personnel.

An MSA helps the parties change contracted services more quickly than without an MSA, because services do not have to be renegotiated each time there is a mutually agreed-upon change to underlying services. For example, a financial institution and a third-party core banking platform product or service provider may enter into an MSA that covers the core banking platform and the possible use of related software and services (e.g., payments software, consulting services, and cloud storage platform). Therefore, changes to the listed services noted in the MSA could occur without creating a new agreement.

MSAs typically include items such as the following:

- Service overview.
- Terms of agreement (e.g., payment, audit, subcontracting, or confidentiality).
- Proprietary rights.
- Intellectual property rights.
- Insurance and taxes.
- Representations and warranties (e.g., patents and trade secrets).

²²⁵ Refer to GSA, “[PWS, SOO, SOW - Finding the Best Fit](#),” for more information.

²²⁶ Refer to GSA, “[Respond to a Solicitation](#),” for more information.

²²⁷ Refer to GSA, “[Performance Work Statement](#),” for more information.

- Limitation of liabilities (e.g., a force majeure clause).²²⁸
- Dispute resolution process.
- Agreement termination process.
- Legal jurisdiction (e.g., country, state, federal, or local).

VI.E.3 Service Level Agreement

An SLA is a formal agreement between two parties that records a common understanding about products or services to be delivered and how they will be delivered, including the following:

- Priorities, responsibilities, guarantees, and warranties between the parties.
- Nature, quality, security, availability, and scope.
- Timeliness of delivery and response of the parties.
- Point(s) of contact for end-user problems.
- Metrics to monitor the effectiveness of the process.
- Approvals.
- Other measurable objectives.
- Expected day-to-day situations and unexpected or adverse events.

An SLA represents a commitment between a third party and one or more customers and addresses specific aspects of the service, such as responsibilities, details on the type of service, expected performance level (e.g., reliability, acceptable quality, and response times), and requirements for reporting, resolution, and termination.²²⁹

SLAs are an effective practice to mitigate the risk of differing performance expectations. When procuring services related to a system or component, agreements should have clear and measurable expectations for the services provided, recourse when expectations are not met, and accountability for both parties. SLAs generally include how the third party expects to meet the SLA requirements and establishes incentives for the third party to meet, or penalties for failing to meet, those requirements. The SLA should be linked to clauses in the contract regarding incentives, penalties, and contract termination to protect the entity in the event of third-party performance failures. For more information, refer to the *FFIEC IT Handbook's* "[Outsourcing Technology Services](#)," "[Management](#)," and "[Information Security](#)" booklets.

VI.E.4 Contracts

Contracts between an entity and its third parties should clearly describe the rights and responsibilities of the respective parties. Contracts are formal binding documents, usually preferable to agreements, which can be informal and may not be enforceable in a court of law.

²²⁸ A contract or agreement clause pertaining to "[force majeure](#)" (i.e., "act of God") risk, irresistible force, or uncontrollable event (e.g., war or civil unrest) that refers to an event or circumstances "when business is disrupted due to a factor beyond control." This type of clause allocates the risk of loss if performance is hindered, delayed, or prevented because of an event that the parties could not have anticipated or controlled. It helps provide a contractual defense, the scope and effect of which depends on the express terms of a particular contract.

²²⁹ Refer to NIST SP 800-47, rev. 1, [Managing the Security of Information Exchanges](#).

An example of important rights to specify are license rights²³⁰ when the entity is using systems and components developed by third parties. Another example is rights and liabilities relating to leased hardware necessary to operate related software. The consequences for failure to meet contractual obligations should also be specified. Examples of software development and maintenance-related contract clauses may include the following:

- Software functional and performance specifications.
- Development process milestones and associated payments.
- Development roles and responsibilities for the third party and the entity.
- SLA information and pricing methods.
- Controls over foreign based third-party activities (i.e., activities performed by entities subject to international laws and regulations).
- Software modification restrictions.
- Objective pre-acceptance performance standards to measure the software's functionality. For example, the contract may identify particular tests that will be used to determine whether the software complies with the contract's performance and security standards.
- Training specifications.

Examples of hardware development or maintenance-related contract clauses may include the following:

- Hardware may not be altered from OEM status, as-delivered (i.e., alterations may void the contract or warranty).
- Proprietary hardware remains the property of the vendor or service provider, and access to it is limited.

A third-party's contributions to the mitigation of major risks are particularly important to specify in contract clauses. For example, security and privacy standards to be followed by third-party service providers or vendors that process, store, or transmit sensitive customer data should be specified in the contract. Table 4 has additional examples of contract clauses.

Table 4: Contract Clause Examples

Clause	Considerations
Legal and regulatory requirements	Outlines responsibility for maintaining software so functionality complies with applicable laws and regulations.
Representations, warranties, and indemnifications	Express representations, warranties, and indemnifications including provisions such as: • Licensed software does not infringe on the intellectual property rights of any third parties worldwide.²³¹

²³⁰ Typically, the developing entity provides licenses to the entity that is using the systems or components, granting it certain rights for their use.

²³¹ Under some state laws, noninfringement warranties are limited to the United States unless otherwise specifically stated.

Clause	Considerations
	- Warranties²³² that software performs according to specifications and how a third party responds in the event of problems. - Specifications for the length of the warranty and how the warranty relates to maintenance obligations and agreements. - Representations that software does not contain undisclosed restrictive code or automatic restraints not specifically authorized in the agreement.
Third-party liability limitations	Proposed limitations of liability in the contract should be reasonable based on the amount of loss or disruption the entity might experience. For mission-critical systems or components, broad exculpatory (i.e., cleared from fault) clauses limiting a third party's liability could adversely affect the safety and soundness of an entity (e.g., excessive force majeure clauses and nested third-party activity exclusions that exceed the entity's capital risk parameters).
Payments	Payment schedule and expense details (e.g., installation, conversion, maintenance, and travel). A payments clause may include provisions such as: - Partial payments at specified development milestones, with final payment due after successful system and component acceptance tests. Properly defined milestones can break development projects into segments with deliverables, allowing management to monitor developer progress and identify any potential problems. - Determination of compensation (e.g., based on the developer's time and materials versus a fixed-price agreement with specific payment milestones). Clearly defined compensation information allows for management control over the development process and total project costs. - Consequences if the third party fails to meet any of the requirements stipulated in the contract, such as failure to deliver system or component features and functions. The contract should allow for the right to reject the deliverable and withhold payment until the third party meets all contractual requirements.
Dispute resolution	Dispute resolution clauses specify the process to be used to resolve problems in a timely manner. Dispute resolution clauses may specify that system and component development will continue during a dispute resolution process.
Agreement modifications	These clauses mitigate the risk that the agreement is not modified without appropriate approval because agreement modification may affect pricing or result in necessary modification to systems and components.
Bankruptcy²³³	Clauses that protect the examined entity in the event of third-party bankruptcy. For example, a clause may specify a software code escrow process that would provide the entity access to the code (that is ordinarily accessed only by the third party) in the event of the third party's insolvency. A second example is a clause specifying that the entity will have direct access to cloud-based services and production data used by the third party for the entity's benefit in the case of the third party's bankruptcy.
Information security	Clauses that identify the information security requirements (e.g., compliance or performance standards) and align with the entity's information security program. Refer to the <i>FFIEC IT Handbook's</i> "Information Security" booklet. Examples are: - Clauses that specify the third party's ongoing responsibilities for maintaining the information security and confidentiality of an entity's resources and data. Provisions should address prohibitions on the third party and its contractors or agents using or disclosing an entity's information, except as necessary to provide contracted services. - Clauses guaranteeing that third party-developed systems and components do not and will not permit unauthorized or unknown access (e.g., "backdoors") to the system, component, or the entity's systems or data.

²³² Warranties generally address events and distinguish between mission-critical failures, which should receive an expedited response, and noncritical failures, which management can resolve in a routine manner. It is helpful to review warranties compared to the latest independent certification report demonstrating the software's capabilities.

²³³ Refer to relevant provisions of the [U.S. Bankruptcy Code](#).

Clause	Considerations
	- Clauses that specify the third party's actions in a breach, such as reporting requirements regarding the incident, its resolution, and communication timeliness. For more information on incident response, refer to the <i>FFIEC IT Handbook's</i> "Information Security," "Outsourcing Technology Services," and "Business Continuity Management" booklets. - Legal, regulatory, and entity standards. For example, applicable regulatory standards include GLBA²³⁴ for financial institutions and the Federal Trade Commission's (FTC) <i>Standards for Safeguarding Customer Information</i> for financial institutions subject to the FTC's enforcement authority.²³⁵
Change in control	Clauses addressing contract revision after third party change of control (e.g., merger, acquisition, or change of ownership). This is important as service quality and support may not be maintained after a change in control.
Subcontracting	- Clauses specifying that the third party is responsible for the performance and security of the systems and components regardless of who designed or developed them. Some third parties may subcontract with other parties (referred to as subcontractors or fourth parties) to develop systems and components for their customers. - Notification and approval requirements regarding changes in subcontractors. Management should consider contract clauses that allow for a contract to be revisited if a key subcontractor changes, which may affect critical entity services. For more information, refer to the <i>FFIEC IT Handbook's</i> "Outsourcing Technology Services" booklet.
Audit	"Right to audit" clause allowing for periodic audits of critical third parties' operations. Periodic audits help validate that third-party service providers comply with the agreement's control terms such as the entity's information security requirements.
Continuing vendor support	Clause regarding system and component support including upgrading, patching, and bug fixing through EOL. The clause should include a minimum time frame for notification of the EOL date.

Appropriate entity personnel should be involved in contract drafting to help ensure that contracts cover all relevant aspects of the development, acquisition, and maintenance of the entity's systems, components, and services, including those that are customized for the examined entity. Contracts should contain such details as performance specifications, source code accessibility, software and data security, and hardware viability and replacement. Contracts should identify the recourse available to the entity if the vendor fails to meet defined requirements and user acceptance criteria. For more information, refer to the *FFIEC IT Handbook's* "[Outsourcing Technology Services](#)" booklet.

Before opening negotiations or issuing an RFP for customized systems and components, management should define objectives and understand the entity's present and planned IT

²³⁴ Refer to [GLBA](#) further implemented by FFIEC members as follows: FDIC: 12 CFR 364, appendix B, "[Interagency Guidelines Establishing Information Security Standards](#)," and 12 CFR 364, supplement A to appendix B, "[Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice](#)"; FRB: Regulation H, 12 CFR 208, appendix D-2, "[Interagency Guidelines Establishing Information Security Standards](#)," and Regulation Y, 12 CFR 225, appendix F, "[Interagency Guidelines Establishing Information Security Standards](#)"; NCUA: 12 CFR 748, appendix A, "[Guidelines for Safeguarding Member Information](#)"; OCC: 12 CFR 30, appendix B, "[Interagency Guidelines Establishing Information Security Standards](#)," (especially the requirement under Section III, D.2, for national banks and federal savings associations to "[r]equire its service providers by contract to implement appropriate measures designed to meet the objectives of these Guidelines").

²³⁵ Refer to FTC 16 CFR 314, "[Standards for Safeguarding Customer Information](#)."

architecture, infrastructure, and operations. During contract negotiation, entity management may encounter situations in which third parties cannot or will not agree to the terms an entity sets out in the draft contract. Under such circumstances, management should determine whether it is willing to accept or can mitigate the risks related to systems or components without the requested terms. Any accepted risk or compensating control factors should be clearly documented with appropriate approval consistent with the entity's policies and governance structure. If management cannot accept or mitigate the risk, it is important to consider alternative solutions. After contract negotiation or agreement execution, periodic audits help to verify that the third party is meeting its contractual responsibilities, such as agreed-on security controls and compliance with laws and regulations.

When negotiating contracts or agreements, management should anticipate that it may decide to convert to different products or providers in the future. Contracts or agreements should enable and facilitate conversions (e.g., minimize restrictions or provide appropriate assistance) to new systems or components. For example, when converting to a different product at the same provider, management and the provider should facilitate coordination between the old and new product teams and entity personnel should be aware of any differences among the products (e.g., hardware, interfacing software, and storage). Additionally, clauses should provide the ability to convert data to a new format as needed. Finally, if converting to a new provider, clauses that allow the old and new providers to coordinate in the conversion process may mitigate conversion related issues (e.g., incompatibility, integration problems, or lack of data availability).

VI.E.5 Escrowed Source Code Agreements and Documentation

Programs are written using proprietary or open-source code. Proprietary systems and components are normally copyrighted trade secrets of the company that wrote or owns the programs. Generally, to protect the integrity of code and software copyrights, vendors do not release proprietary code to the entities that buy or lease the products. Typically, an independent third-party escrow agent retains the source code and related documentation in escrow;²³⁶ however, entity management is responsible for verifying annually that the third party maintains a current version of the source code in escrow. Some escrow agents provide services for reviewing and confirming source code version numbers and dates. Some agents perform automated code reviews to confirm integrity of the escrowed code.

The documentation held by the escrow agent should include system narratives, system flowcharts, program source listings, program narratives, file and record layouts, descriptions of individual fields in the records, and calculation routines. Portions of this documentation may be included with the user guides that are provided to the entity. These documents should cover transaction codes and descriptions of input forms and output reports. In addition, management should consider protecting the entity's escrow rights by contractually requiring third parties to inform the entity if the software vendor pledges the software as loan collateral. It is important to consider the risks associated with a foreign-based escrow agreement.

²³⁶ Merriam-Webster defines "[escrow](#)" as "a deed, a bond, money, or a piece of property held in trust by a third party to be turned over to the grantee only on fulfillment of a condition." For purposes of this booklet, the code in escrow is held by a third party and provided to the entity only on the fulfillment of some condition.

Effective escrow agreement provisions may include the following:

- Requirements to include minimum code documentation with the code in escrow.
- System and component maintenance procedure documentation to be escrowed.
- Conditions that should be present before an entity can access the source code and related documentation.
- Assurances that the escrow agent will hold current versions of the source code and related documentation to validate that escrowed information is updated whenever significant program changes are made.
- Arrangements for auditing or testing escrowed code integrity.
- Source code descriptions and related documentation including the storage type and location (e.g., magnetic tape or cloud).
- Assurances that the source code storage type and location and related documentation is accessible, operable, and compatible with an entity's existing IT environment.
- Assurances that the source code can be compiled into executable code.
- If the escrow agent is based outside the United States, consideration of the practical and legal implications of establishing foreign-based escrow arrangements.

VI.E.6 Exit Strategy

An exit strategy is an entity's plan for transitioning to a replacement system, component, or service, or for terminating a system, component, or service. Entities design exit strategies to minimize disruption. Having a well-defined exit strategy is part of ongoing, effective strategic planning. During the procurement process, management should develop an exit strategy that at a minimum addresses the third party not meeting the contract terms.

To have the most leverage, entity personnel should negotiate default and termination language in the initial contract. The default and termination language may provide opportunities or methods to remedy contract defaults. Contract clauses should define termination rights; document time frames for transferring services to another third party or bringing the service in-house; and provide for how data, records, and IT assets are preserved, transferred, or destroyed.

Default and termination language may provide for the initial steps in executing an exit strategy, but it is important to consider identifying alternative third parties that provide similar products and services at the onset of the relationship. This could provide management with an initial plan to execute a transition between third parties. For more information on exit strategy planning, refer to the *FFIEC IT Handbook's* "[Management](#)," "[Outsourcing Technology Services](#)," and "[Business Continuity Management](#)" booklets.